Informe de auditoría del sistema

Sistema de citas · Clínica Veterinaria UDES

Fecha	11 de octubre de 2026
Versión revisada	Rama `incremento-3-administrativo`, 298 commits
Alcance	Servidor (Express, 77 archivos), base de datos (PostgreSQL, 21 tablas), frontend (React, 170 archivos) y repositorio
Tipo de revisión	Solo inspección. La auditoría no modificó código ni datos.

Resumen

El sistema está completo en funciones y su base de seguridad es sólida: no encontré vulnerabilidades críticas. Sí encontré **62 observaciones**, de las cuales **12 son de prioridad alta**. Las más importantes no son de seguridad sino de uso y de lógica: en celular faltan el menú y el cierre de sesión, el panel de administración no se puede navegar en pantallas pequeñas, una sesión vencida no se detecta, y el agendamiento ignora la duración del servicio y depende de la zona horaria del servidor.

12
Alta: corregir antes de mostrarlo o usarlo

25
Media: corregir antes de usuarios reales

22
Baja: mejora recomendable

3
Informativa

ÁREA	ALTA	MEDIA	BAJA	INFO	TOTAL
Seguridad	1	9	8	1	**19**
Errores de lógica	3	6	3	–	**12**
Base de datos	–	1	2	1	**4**
Código y archivos sin uso	–	1	5	1	**7**
Accesibilidad (WCAG 2.1 nivel AA)	3	4	2	–	**9**
Experiencia de uso y diseño	3	2	2	–	**7**
Rendimiento	2	2	–	–	**4**

Para llevarlo a producción real el sistema **todavía no está listo**: además de lo anterior faltan la política de privacidad con autorización de datos, la verificación de correo al registrarse y la configuración de despliegue. Para la entrega académica en entorno local, lo que más se nota está en el primer bloque del plan de acción, al final.

Cómo se hizo la revisión

- **Lectura de código** de autenticación, permisos por rol, citas, mascotas, horarios, datos, copias de seguridad, subida de archivos y correos.
- **Pruebas en vivo contra la API local**, solo con peticiones que no guardan nada: cabeceras, orígenes permitidos, rutas sin sesión y datos inválidos.
- **Consultas de solo lectura a la base**: esquema, índices, restricciones y consistencia de los datos.
- **Navegador sin interfaz** (Edge) con axe-core 4.10 en 12 pantallas, a 1440 px y a 390 px: accesibilidad, contraste, desborde, zonas táctiles, foco de teclado, metadatos, imágenes y enlaces.
- **Análisis del proyecto**: archivos y funciones sin uso, dependencias, avisos de seguridad de npm, lint, pruebas con cobertura y peso de la versión compilada.

> **Límites de esta revisión.** Las pantallas de administrador, superadministrador y cliente no se abrieron en el navegador: se revisaron por código. Las mediciones de accesibilidad corresponden a las páginas públicas y a la vista del médico (con la cuenta de ejemplo). No se hicieron pruebas de carga ni de intrusión agresiva, ni se comprobó la llegada real de correos. El contraste de los textos sobre vidrio o degradado no lo puede medir una herramienta automática.

Lo que está bien

- Todas las consultas a la base usan parámetros; las partes armadas con texto son constantes del código.
- Contraseñas con bcrypt. Códigos de recuperación cifrados, con vigencia de 15 minutos, 5 intentos y uno por minuto.
- El archivo `.env` no está en el repositorio ni en su historial. El secreto de los tokens tiene 96 caracteres.
- Todas las rutas de escritura exigen sesión y rol. Comprobado en vivo: 401 sin token, 403 con rol equivocado, 404 en rutas inexistentes.
- Citas, mascotas, notificaciones y horarios comprueban que el registro sea de quien lo pide o de su sede.
- Cabeceras de seguridad, lista de orígenes permitidos (CORS), límite de intentos, tamaño máximo de 5 MB y verificación de que el archivo sea realmente una imagen.
- Los errores inesperados responden un mensaje genérico; el inicio de sesión no revela por mensaje si el correo existe.
- Un índice único impide dos citas del mismo médico a la misma hora aunque dos personas confirmen a la vez.
- La exportación a CSV neutraliza fórmulas y la bitácora omite contraseñas y códigos.
- El frontend no inserta HTML sin escapar, los enlaces externos llevan `rel="noopener"` y el parámetro de redirección tras iniciar sesión se valida contra una lista.
- Las 406 pruebas del servidor pasan y el frontend compila.

Seguridad

No encontré vulnerabilidades críticas: no hay inyección SQL, ninguna ruta de escritura funciona sin sesión, y no hay contraseñas ni llaves en el repositorio. Lo que sigue son debilidades que importan sobre todo si el sistema sale a producción con usuarios reales.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
SEG-01 **Alta**	**Un cambio de rol o de sede no surte efecto hasta que vence la sesión (hasta 8 horas)** El rol y la sede viajan dentro del token. En cada petición el servidor vuelve a consultar si la cuenta sigue activa, pero no su rol. Si el superadministrador le quita el rol de administrador a alguien, esa persona conserva sus permisos hasta que el token expire. `backend/src/middlewares/auth.middleware.js` (`verificarRol` usa el token), `usuario.controller.js` (`cambiarRol`). **Qué hacer:** Leer el rol y la sede de la base junto con el estado activo (ya existe la consulta con caché de 30 segundos), o invalidar los tokens de la cuenta al cambiarle el rol.
SEG-02 **Media**	**Cambiar o restablecer la contraseña no cierra las sesiones abiertas** Los tokens emitidos antes del cambio siguen sirviendo hasta 8 horas. Si alguien robó una sesión, cambiar la clave no lo saca. Aplica a recuperación por código, cambio desde el perfil y primera clave. **Qué hacer:** Guardar en la cuenta la fecha del último cambio de contraseña y rechazar tokens emitidos antes.
SEG-03 **Media**	**La sesión se guarda en localStorage y el sitio no define una política de contenido (CSP)** No encontré ningún punto de inyección de HTML en el frontend (no se usa `dangerouslySetInnerHTML` ni `eval`), así que hoy no hay un ataque concreto. Pero si algún día aparece uno, el token se puede leer con JavaScript. La API sí envía CSP; el HTML de la aplicación no. **Qué hacer:** Configurar CSP en el hosting del frontend. A mediano plazo, evaluar cookie `httpOnly` en vez de localStorage.
SEG-04 **Media**	**El registro no verifica que el correo sea de quien se registra** Cualquiera puede crear una cuenta con el correo de otra persona. Además el correo de bienvenida incluye el nombre tal como se escribió, sin límite de longitud ni validación: sirve para enviar texto arbitrario a un tercero desde el correo de la clínica. `auth.controller.js` (`registrar`). **Qué hacer:** Confirmar el correo con un código (el mecanismo de 6 dígitos ya existe) antes de activar la cuenta, y validar el nombre.
SEG-05 **Media**	**Los correos no se normalizan** `Ana@correo.com` y `ana@correo.com` se tratan como cuentas distintas y el inicio de sesión distingue mayúsculas. Solo la corrección desde Datos pasa el correo a minúsculas. No hay duplicados hoy en la base. **Qué hacer:** Guardar y comparar siempre en minúsculas y sin espacios (registro, inicio de sesión, alta de personal, cambio de correo).

SEG-06 — Media

Varios campos no se validan y el error llega hasta la base de datos (respuesta 500)
Comprobado en vivo: un nombre de 200 caracteres o un teléfono de 31 en el registro devuelven 500. Lo mismo aplica por lectura de código a los textos de mascota, fecha de nacimiento y horas del horario. No filtra información (el mensaje es genérico) pero es un error del servidor donde debería haber un aviso claro.

Qué hacer: Validar longitud y formato en cada controlador y responder 400 con el campo que falla.

SEG-07 — Media

Un médico puede consultar las mascotas de cualquier cliente, incluida su información médica
`GET /api/mascotas?clienteId=` acepta el rol veterinario sin comprobar que el cliente sea paciente suyo (esa comprobación sí existe para crear y editar). Devuelve alergias, medicamentos y condiciones médicas. `mascota.controller.js` (`listarDeCliente`).

Qué hacer: Aplicar la misma regla `puedeGestionarMascotasDe` a la consulta.

SEG-08 — Media

El campo `fotoUrl` de la mascota acepta cualquier dirección externa
Aunque la interfaz sube archivos, la API todavía guarda una URL escrita a mano, que luego se muestra como imagen a médicos y administradores. Sirve como píxel de rastreo.

Qué hacer: Dejar de aceptar `fotoUrl` en crear y editar; la foto solo por la ruta de subida.

SEG-09 — Media

La copia de seguridad completa se descarga solo con la sesión del superadministrador
El archivo incluye toda la base (datos personales y contraseñas cifradas) y viaja sin cifrar. No se pide la contraseña de nuevo. `datos.controller.js` (`respaldo`).

Qué hacer: Pedir la contraseña antes de generar la copia y documentar dónde se guarda. En producción, copias automáticas del lado del servidor.

SEG-10 — Media

La aplicación se conecta a PostgreSQL con el usuario `postgres` (superusuario)
Es lo normal en desarrollo. En producción, un fallo en la aplicación tendría permisos totales sobre el servidor de base de datos. Tampoco hay configuración de SSL para la conexión.
`backend/src/config/db.js`.

Qué hacer: Crear un usuario propio con permisos solo sobre esta base y activar SSL.

SEG-11 — Baja

Política de contraseñas mínima y sin bloqueo por cuenta
Solo se exigen 8 caracteres. El límite de intentos es por dirección IP (20 cada 15 minutos), no por cuenta. El inicio de sesión responde más rápido cuando el correo no existe, y el registro dice si un correo ya tiene cuenta: ambos permiten averiguar qué correos están registrados.

Qué hacer: Rechazar contraseñas muy comunes, añadir un tope por cuenta y igualar los tiempos de respuesta.

SEG-12 — Baja

La clave temporal del personal no vence
Una cuenta creada por el administrador que nunca entra conserva indefinidamente la clave enviada por correo.

Qué hacer: Darle vigencia (por ejemplo 72 horas) y permitir reenviarla.

SEG-13 — Baja

La bitácora solo registra cambios de configuración exitosos
No quedan registrados inicios de sesión fallidos, accesos denegados ni operaciones sobre citas. El resto del registro va solo a la consola del servidor.

Qué hacer: Registrar eventos de seguridad y enviar los registros a un archivo o servicio con retención.

SEG-14	Baja	**El límite de intentos vive en la memoria del servidor** Se pierde al reiniciar y, detrás de un proxy sin `TRUST_PROXY`, todas las personas comparten la misma IP. Crear citas y reenviar la confirmación no tienen límite (permite abusar del correo). **Qué hacer:** Documentar `TRUST_PROXY` para el despliegue y añadir límites a esas dos rutas.
SEG-15	Baja	**`/api/health` es público y devuelve el detalle del error de la base de datos** También muestra la hora del servidor. `health.controller.js`. **Qué hacer:** Responder solo "ok" o "error" hacia afuera.
SEG-16	Baja	**Las fotos subidas se sirven sin sesión y conservan sus metadatos** Los nombres son aleatorios (no se pueden adivinar), pero quien tenga el enlace ve la foto. Las fotos enviadas directo a la API no se recodifican, así que pueden conservar ubicación GPS. **Qué hacer:** Aceptable para este alcance. En producción, recodificar en el servidor.
SEG-17	Baja	**Dependencias con avisos de seguridad** Backend: 0 en producción, 22 en herramientas de desarrollo (jest, nodemon). Frontend: 4 (2 altas en herramientas de compilación, 2 moderadas por `exceljs` → `uuid`). Ninguna es explotable en el uso actual. **Qué hacer:** Ejecutar `npm audit fix` y revisar `exceljs` cuando publique una versión corregida.
SEG-18	Baja	**No hay archivo `.env.example` y el servidor arranca sin comprobar su configuración** Si falta `JWT_SECRET`, el error aparece recién al iniciar sesión. El secreto actual tiene 96 caracteres, lo cual está bien. **Qué hacer:** Añadir `.env.example` y validar las variables al arrancar.
SEG-19	Info	**La guía de diseño `/vetui` es pública** Es una página interna de trabajo. No expone datos. **Qué hacer:** Dejarla fuera de la versión de producción o protegerla.

Errores de lógica

Reglas del negocio que el sistema no hace cumplir o que fallarían en condiciones distintas a las de hoy.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
LOG-01 Alta	**La duración del servicio no se tiene en cuenta al agendar** Las franjas son fijas de 30 minutos y el choque de citas se revisa por hora exacta. El superadministrador puede poner un servicio de 5 a 480 minutos; con una cirugía de 90 minutos a las 8:00, el sistema ofrecería al mismo médico a las 8:30. Hoy los 9 servicios duran 30 minutos, por eso no ha ocurrido. `utils/franjas.js`, `cita.model.js` (`existeConflicto`). **Qué hacer:** Ocupar tantas franjas como dure el servicio, o limitar la duración a 30 minutos mientras tanto.
LOG-02 Alta	**Las horas dependen de la zona horaria de la máquina donde corre el servidor** Las fechas se arman en hora local y las columnas son `timestamp` sin zona. En este equipo (Bogotá) funciona; en un hosting típico (UTC) las franjas se correrían 5 horas y el día de la semana fallaría cerca de medianoche. **Qué hacer:** Fijar `TZ=America/Bogota` en el servidor como mínimo; lo correcto es migrar a `timestamptz`.
LOG-03 Alta	**El frontend no detecta que la sesión venció** Pasadas 8 horas el navegador sigue mostrando el panel porque solo mira si hay un token guardado. Cada acción falla con "Token inválido o expirado" y la persona no es llevada a iniciar sesión. Lo mismo pasa cuando el servidor responde "sesión terminada" por cuenta desactivada. `frontend/src/api/client.js`, `AuthContext.jsx`. **Qué hacer:** Ante un 401, cerrar la sesión local y enviar a iniciar sesión con un mensaje.
LOG-04 Media	**Se puede cancelar o reprogramar una cita que ya pasó** Solo se valida que la cita esté "agendada" y que la nueva fecha sea futura, no que la cita original lo sea. Una cita atendida ayer se puede cancelar o mover a la próxima semana, lo que altera reportes e historial. `cita.controller.js`. **Qué hacer:** Rechazar ambas operaciones si la cita ya ocurrió.
LOG-05 Media	**No hay tope de citas por cliente ni por mascota** En la base hay un caso real de la misma mascota con dos citas a la misma hora. Un cliente podría reservar toda la agenda de un día. **Qué hacer:** Impedir dos citas simultáneas de la misma mascota y fijar un máximo de citas futuras por cliente.
LOG-06 Media	**Al agendar no se comprueba que el servicio, la sede y el cliente estén activos** La asignación automática sí filtra médicos activos, pero cuando el administrador elige el médico no se revisa su estado. Tampoco se revisa `servicio.activo` ni `sede.activo`, ni que el cliente al que se le agenda esté activo. `cita.controller.js` (`crear`). **Qué hacer:** Añadir esas cuatro comprobaciones.

LOG-07	Media	**El administrador de sede y el médico no pueden cancelar ni reprogramar citas** Solo el cliente dueño puede hacerlo (y el superadministrador desde Datos). Si un médico se enferma, el bloqueo impide citas nuevas pero las ya agendadas quedan en pie y nadie de la sede puede moverlas ni se avisa al cliente. **Qué hacer:** Permitir a la sede cancelar o reprogramar con aviso al cliente, y ofrecerlo al crear un bloqueo.
LOG-08	Media	**Cambios que dejan citas futuras huérfanas no avisan** Cerrar un día o acortar el horario de la sede, desactivar un médico, cambiarle el rol o quitarle un servicio no revisa las citas ya agendadas. Los bloqueos sí cuentan las citas afectadas. **Qué hacer:** Contar las citas afectadas antes de guardar y pedir confirmación.
LOG-09	Media	**Las horas del horario de atención se comparan como texto** `"9:00" >= "17:00"` es verdadero al comparar texto, así que la API rechazaría un horario válido escrito sin cero inicial, y una hora imposible llega a la base (500). La interfaz siempre envía `09:00`, por eso no se nota. `horario.controller.js`. **Qué hacer:** Validar el formato `HH:MM` y comparar en minutos, como ya hace el horario del médico.
LOG-10	Baja	**Una cita solo puede estar "agendada" o "cancelada"** "Completada" se deduce de la fecha. No se puede registrar que el paciente no asistió ni que la cita fue atendida, y los reportes cuentan como atendidas todas las pasadas. **Qué hacer:** Añadir los estados "atendida" y "no asistió".
LOG-11	Baja	**Fechas imposibles se aceptan en la consulta de disponibilidad** `2026-02-31` se interpreta como 3 de marzo. El año del código de la cita sale de la fecha en que se crea, no de la fecha de la cita. **Qué hacer:** Validar la fecha y decidir cuál año debe llevar el código.
LOG-12	Baja	**Los recordatorios automáticos corren dentro del servidor web** Con dos instancias se enviarían duplicados. Suficiente para un solo servidor. **Qué hacer:** Documentarlo como límite conocido.

Base de datos

21 tablas. La integridad básica está bien: llaves foráneas, restricciones de valores e índice único que impide dos citas del mismo médico a la misma hora.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
BD-01 Media	**La base se arma con 26 scripts sueltos** No hay esquema consolidado, ni registro de cuáles migraciones se aplicaron, ni instrucciones de orden. Uno crea tablas que otro posterior borra (`7a` y `8c`). Instalar desde cero depende de ejecutarlos a mano en el orden correcto. **Qué hacer:** Generar un `esquema.sql` único y un instructivo de instalación; conservar los incrementos como historial.
BD-02 Baja	**Cuatro llaves foráneas sin índice** `cita.mascota_id`, `servicio.categoria_id`, `usuario_especialidad.categoria_id`, `recordatorio.cliente_id`. Con el volumen actual no se nota. **Qué hacer:** Crear los índices.
BD-03 Baja	**Las dos sedes tienen la dirección vacía** El enlace a Google Maps busca solo por nombre y el correo de confirmación de la cita sale sin dirección. **Qué hacer:** Completar las direcciones desde Sedes.
BD-04 Info	**Datos de ejemplo y reales conviven en la misma base** 16 clientes, 26 mascotas y 296 citas de ejemplo (`@demo.udes.co`). Los reportes los cuentan. **Qué hacer:** Ejecutar `npm run demo:quitar` antes de cualquier uso real.

Código y archivos sin uso

Todos los componentes, páginas, controladores, modelos y rutas están en uso: no hay pantallas ni módulos muertos. Lo que sobra son archivos de imagen y algunos restos.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
COD-01 Media	**18 archivos de imagen que ningún código usa (2,8 MB)** En `frontend/src/assets/`: restos de la plantilla de Vite (`react.svg`, `vite.svg`, `hero.png`), `logo-azul.png` (664 KB), las 9 fotos de `servicios-foto/` (1,9 MB; ahora las fotos de servicios vienen de la base) y 5 versiones `.webp` de logos y foto principal que quedaron sin conectar. **Qué hacer:** Borrar los que sobran y conectar los `.webp` (ver Rendimiento).
COD-02 Baja	**El ícono de la pestaña es el de la plantilla de Vite** `public/favicon.svg` es el rayo morado de Vite. `favicon.png` e `icono-180.png` con el logo de la clínica están en la carpeta pero `index.html` no los enlaza. `public/icons.svg` tampoco se usa. **Qué hacer:** Enlazar los íconos correctos y borrar los de la plantilla.
COD-03 Baja	**Funciones exportadas que nadie llama** `obtenerPerfil` (`api/client.js`, y con ella la ruta `GET /api/auth/perfil` queda sin consumidor), `IconoEngranaje`, `IconoDestello`, `edadDeMascota`, `razaEsTextoLibre`. **Qué hacer:** Eliminarlas.
COD-04 Baja	**Documentación desactualizada o fuera del repositorio** `frontend/README.md` es el de la plantilla. El alcance dice que el próximo paso es el Incremento 1. Los requerimientos e historias de usuario están en `infoproyecto/`, que no está versionado, aunque el alcance los cita en `/docs`. Varios comentarios describen permisos antiguos (por ejemplo "solo administrador" donde ya es superadministrador). **Qué hacer:** Actualizar esos textos y versionar los requerimientos.
COD-05 Baja	**El lint reporta 22 problemas** 20 errores y 2 avisos, casi todos de la regla `react-hooks/set-state-in-effect`. No rompen nada, pero ocultan errores nuevos. **Qué hacer:** Corregirlos o ajustar la regla de forma explícita.
COD-06 Baja	**Las pruebas no tocan la base de datos real** 406 pruebas del servidor pasan, con cobertura de 74 % de líneas y 55 % de funciones. Todas simulan los modelos, así que un error de SQL no lo detectan. El frontend no tiene pruebas automáticas. **Qué hacer:** Añadir un grupo pequeño de pruebas de integración contra una base de pruebas.
COD-07 Info	**El remoto de git apunta a un repositorio de prueba** `origin` es `prueba-motion-graphics`, usado para trabajar en la nube y para video. Contiene el proyecto completo hasta el 10 de octubre. **Qué hacer:** Tenerlo presente para la entrega final: el repositorio definitivo será otro.

Accesibilidad (WCAG 2.1 nivel AA)

Medido con axe-core 4.10 en 12 pantallas, en escritorio y en celular. Lo que cumple: idioma declarado, ninguna imagen sin texto alternativo, foco visible al navegar con teclado, campos con autocompletado correcto, y las animaciones se apagan con "reducir movimiento".

N.º	OBSERVACIÓN Y RECOMENDACIÓN
ACC-01 Alta	**Botones sin nombre para lectores de pantalla** Dos botones de solo ícono en "Mis citas" del médico (flechas del calendario) no tienen texto ni `aria-label`. Un lector de pantalla los anuncia solo como "botón". Criterio 4.1.2. **Qué hacer:** Añadir `aria-label` a todo botón de solo ícono; revisar igual las pantallas de administración.
ACC-02 Alta	**Paneles cerrados que siguen recibiendo el foco del teclado** Los paneles laterales y la ventana de foto, cuando están cerrados, quedan en la página marcados como ocultos pero con sus botones y campos alcanzables con Tab. Quien navega con teclado entra a contenido que no ve. Criterio 4.1.2. `ui/SidePanel.jsx`, `FotoMascotaModal`. **Qué hacer:** Marcar el panel cerrado como `inert` o no dibujarlo.
ACC-03 Alta	**Contraste insuficiente en textos medidos** Mínimo exigido 4,5:1. Medido: etiquetas de cita del calendario 4,13:1 (texto de 11 px `#c23e80` sobre `#fde6f0`, 18 casos); insignia verde "activo" 3,12:1; botón azul principal de los formularios, texto blanco sobre `#4280f7`, 3,7:1; pie de página 3,74:1. Además hay más de 100 textos sobre vidrio o degradado que la herramienta no puede medir y requieren revisión a ojo. **Qué hacer:** Oscurecer esos cuatro colores. Para el botón azul, usar `brand-blue-600` o más oscuro.
ACC-04 Media	**Todas las páginas tienen el mismo título de pestaña** "Clínica Veterinaria UDES" en todas. Criterio 2.4.2: el título debe decir en qué página se está. **Qué hacer:** Título por página ("Iniciar sesión · Clínica Veterinaria UDES").
ACC-05 Media	**Estructura de la página incompleta** Las páginas de sesión no tienen región principal (`<main>`). Las páginas con barra superior tienen dos encabezados de página. Una lista de definición mal formada en el perfil del médico. **Qué hacer:** Añadir `<main>` y dejar un solo `<header>` de página.
ACC-06 Media	**Zonas táctiles menores de 24 px** Los puntos del carrusel de servicios miden 17 px (12 en el inicio); flechas de 22 px; enlaces de texto de 16 a 20 px de alto. Criterio 2.5.8 (WCAG 2.2). **Qué hacer:** Ampliar el área pulsable a 24 px o más, idealmente 44 px en celular.
ACC-07 Media	**Texto de 11 px en la agenda** 34 textos por debajo de 12 px en "Mis citas" del médico. **Qué hacer:** Mínimo 12 px.
ACC-08 Baja	**Las fotos de la portada tienen el texto alternativo vacío** La galería pide una descripción obligatoria al subir cada foto, pero `HeroGaleria.jsx` la dibuja con `alt=""`. La descripción no llega a quien usa lector de pantalla. **Qué hacer:** Usar la descripción guardada como `alt`.

ACC-09

Baja

No hay enlace "Saltar al contenido"

Con teclado hay que pasar por toda la barra superior en cada página.

Qué hacer: Añadirlo como primer elemento.

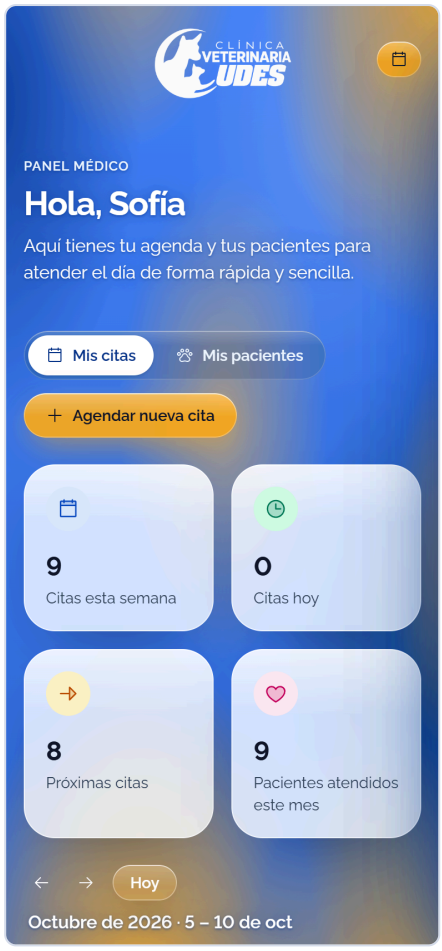
Experiencia de uso y diseño

Las pantallas de administrador, superadministrador y cliente las revisé por código, no en el navegador (no tenía permiso para abrirlas con una sesión). Las públicas y las del médico sí las abrí.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
UX-01 Alta	**En celular la barra superior pierde casi todo** Por debajo de 640 px solo quedan el logo y el botón de agendar. No hay menú: desaparecen Servicios, Sedes y Horarios; un visitante no tiene "Iniciar sesión"; y con sesión iniciada no hay campana, perfil ni "Cerrar sesión". `layout/Navbar.jsx`. **Qué hacer:** Añadir un menú para celular con esas opciones.
UX-02 Alta	**El panel de administración no se puede navegar por debajo de 1024 px** El menú lateral se oculta y no hay alternativa. En tableta o celular solo se ve la pantalla de inicio. Incumple el requisito de diseño adaptable (RNF-02). `layout/AdminSidebar.jsx`. **Qué hacer:** Menú desplegable para pantallas pequeñas.
UX-03 Alta	**Una dirección que no existe muestra una página en blanco** No hay ruta de "página no encontrada". `App.jsx`. **Qué hacer:** Página 404 con el diseño del sitio y un enlace al inicio.
UX-04 Media	**Las fotos de las sedes se cargan desde sitios de terceros** Vienen de un periódico (Vanguardia) y de un blog. Pueden dejar de funcionar en cualquier momento, una pesa varios megas (5472 px de ancho) y no hay permiso de uso. La subida de archivo para sedes ya existe. **Qué hacer:** Subir fotos propias desde Sedes.
UX-05 Media	**El registro no informa qué se hará con los datos personales** Se piden nombre, correo y teléfono sin enlace a una política ni casilla de autorización. Ver la lista de verificación. **Qué hacer:** Casilla de autorización y enlace a la política.
UX-06 Baja	**Conviven dos estilos de botón** Los formularios del panel y del perfil del médico usan un botón azul plano; el resto del sitio usa los botones de vidrio. Es además el botón con contraste insuficiente. **Qué hacer:** Unificar con el sistema de botones del sitio.
UX-07 Baja	**El inicio de escritorio avanza una sección por cada giro de la rueda** Es una decisión de diseño. Conviene confirmar con personas reales que no desorienta. **Qué hacer:** Validarlo en las pruebas con usuarios.



Inicio a 390 px: la barra solo tiene el logo y el botón de agendar (UX-01).



Panel del médico a 390 px, con sesión: sin campana, perfil ni cierre de sesión (UX-01).

Una dirección inexistente: página en blanco (UX-03).

Rendimiento

Medido sobre la versión compilada (`npm run build`). El sitio compilado pesa 8,9 MB.

N.º	OBSERVACIÓN Y RECOMENDACIÓN
REN-01 **Alta**	**Todo el JavaScript va en un solo archivo de 2,72 MB** Quien abre la página de inicio descarga también las librerías de Excel, PDF y gráficos, que solo usa el panel de reportes. No hay carga diferida de pantallas. **Qué hacer:** Cargar cada panel bajo demanda (`React.lazy`) y las librerías de exportación solo al exportar.
REN-02 **Alta**	**Logos y foto principal en PNG sin comprimir: 4,6 MB** `foto-main.png` 1,77 MB; `logoblanco.png` 1,17 MB (1536 px de ancho, se muestra a 126 px); `logocolor.png` 0,69 MB; `logocorto.png` 0,61 MB; `logocortoblanco.png` 0,39 MB. Las versiones `.webp` ya están en la carpeta y suman 244 KB, pero el código sigue importando los PNG. **Qué hacer:** Cambiar las importaciones a los `.webp` y borrar los PNG. Reduce 95 % de ese peso.
REN-03 **Media**	**Imágenes sin tamaño declarado y sin carga diferida** Ninguna imagen declara ancho y alto (la página salta mientras cargan) y 16 de 18 en el inicio se cargan de una vez. **Qué hacer:** Añadir `width`, `height` y `loading="lazy"` a las que no están en la primera pantalla.
REN-04 **Media**	**Los listados no tienen paginación** Citas de la sede, citas del cliente, usuarios y pacientes se devuelven completos. Con datos de un año la respuesta crecerá sin límite. **Qué hacer:** Paginar o acotar por rango de fechas.

Lista de verificación para publicar el sitio

Estado de cada punto de la lista y si conviene hacerlo en este proyecto.

PUNTO	ESTADO HOY	¿HACERLO?	DETALLE
Aviso legal	No existe	Sí, si se publica	Página breve con el responsable del sitio (UDES), datos de contacto y condiciones de uso. Para la entrega académica en local no es obligatorio.
Política de privacidad	No existe	Sí, prioritario	El sistema guarda nombre, correo, teléfono, documento y dirección. En Colombia la Ley 1581 de 2012 y el Decreto 1377 de 2013 exigen autorización previa, decir para qué se usan los datos y cómo ejercer los derechos de consulta, corrección y supresión. Debe alinearse con la política de tratamiento de datos de la UDES. Hace falta una casilla de autorización en el registro. Hoy un cliente tampoco puede eliminar su cuenta.
Aviso de cookies	No aplica hoy	No por ahora	El sistema no usa cookies ni analítica. Solo guarda en el navegador la sesión y la preferencia del menú, que son técnicamente necesarias. Basta mencionarlo en la política de privacidad. Sí haría falta si se añade Google Analytics, mapas incrustados o píxeles de redes.
Forzar HTTPS	Preparado en el servidor	Sí, al desplegar	La API ya redirige a HTTPS y envía HSTS cuando `NODE_ENV=production`. Falta el certificado, `TRUST_PROXY` y la misma redirección en el hosting del frontend.
Meta títulos y descripciones	Falta	Sí	Hay un solo título y ninguna descripción ni etiquetas para compartir en redes. Solo importa para la página de inicio, que es la única pública.
Datos estructurados	Falta	Opcional	Un bloque JSON-LD de tipo `VeterinaryCare` con las dos sedes, horarios y teléfono ayuda a que Google muestre esos datos. Prioridad baja.
Sitemap y robots.txt	Faltan	Sí, sencillo	`robots.txt` que permita el inicio y bloquee `/admin`, `/panel`, `/medico`, `/agendar`, `/vetui` y `/api`. El sitemap tendría una sola dirección.
Ficha de Google	Fuera del sistema	Recomendable	No es código: es el Perfil de Negocio de Google de cada sede, que crea y verifica la clínica. Conviene comprobar si ya existe y enlazarlo.
Favicon	Incorrecto	Sí	Se muestra el ícono de Vite. Los archivos con el logo ya están en `public/`; falta enlazarlos.
Texto alternativo en imágenes	Cumple en lo medido	Ajuste menor	Ninguna imagen sin `alt` en 12 pantallas. Falta que las fotos de la portada usen su descripción.

Imágenes comprimidas	No cumple	Sí	4,6 MB en cinco PNG; las versiones livianas ya existen sin conectar.
Velocidad de carga	No cumple	Sí	Un solo archivo JavaScript de 2,72 MB. Dividirlo es la mejora de mayor efecto.
Contraste de colores	Parcial	Sí	Cuatro combinaciones medidas por debajo de 4,5:1 y más de 100 textos sobre vidrio por revisar a ojo.
Diseño adaptable al móvil	Parcial	Sí	Ninguna de las 12 pantallas se desborda a 390 px, pero falta el menú en celular y el panel de administración no se puede navegar.
Página 404 personalizada	Falta	Sí	Hoy sale una página en blanco.
Enlaces rotos	Cumple	Nada que hacer	Enlaces internos válidos; Google Maps, WhatsApp, Instagram y Facebook responden.
Formularios protegidos contra spam	Parcial	Sí	Ya hay límite de intentos por IP en inicio de sesión, registro y códigos. Falta verificar el correo al registrarse y un campo trampa o CAPTCHA en el registro.

Plan de acción sugerido

Antes de la sustentación

- Página 404 (UX-03)
- Ícono de la pestaña y título por página (COD-02, ACC-04)
- Conectar los `.webp` y borrar imágenes sin uso (REN-02, COD-01)
- Detectar la sesión vencida (LOG-03)
- Menú en celular y en el panel de administración (UX-01, UX-02)
- Nombres de botones, paneles cerrados y los cuatro contrastes (ACC-01 a ACC-03)
- Completar direcciones y fotos propias de las sedes (BD-03, UX-04)

Antes de usarlo con personas reales

- Política de privacidad y autorización en el registro
- Verificación de correo al registrarse (SEG-04)
- Rol revalidado en cada petición y cierre de sesiones al cambiar la clave (SEG-01, SEG-02)
- Duración del servicio y zona horaria (LOG-01, LOG-02)
- Validación de campos y normalización de correos (SEG-05, SEG-06)
- Consulta de mascotas por el médico y `fotoUrl` (SEG-07, SEG-08)
- Citas pasadas, topes y estados activos (LOG-04 a LOG-06)
- Quitar los datos de ejemplo

Al desplegar en producción

- HTTPS, `TRUST_PROXY`, CSP y usuario propio de base de datos (SEG-03, SEG-10)
- Dividir el JavaScript y paginar listados (REN-01, REN-04)
- Esquema único de base de datos e instructivo (BD-01)
- Copias de seguridad automáticas y registro de eventos (SEG-09, SEG-13)
- robots.txt, sitemap, descripción y datos estructurados

Cambios hechos fuera de la auditoría

La auditoría fue solo de inspección. En la misma jornada, por pedido aparte, quedaron dos cambios guardados en el repositorio:

- **Endurecimiento del servidor** (commit `fd20b06`): cabeceras de seguridad, lista de orígenes permitidos, límite de intentos en inicio de sesión, registro y códigos, pérdida de sesión al desactivar una cuenta, redirección a HTTPS en producción, verificación de que las fotos sean imágenes reales y mensajes de error genéricos. Estaba a medio guardar de la sesión anterior; se verificó con las pruebas y se guardó.
- **Horario del médico**: ahora lo define el administrador de su sede (Médicos > Horario) y el médico solo lo consulta. La pantalla del administrador no se abrió en el navegador y nadie ha guardado un horario desde ella todavía.

Anexo: archivos sin uso

- `assets/react.svg`
- `assets/vite.svg`
- `assets/hero.png`
- `assets/logo-azul.png (664 KB)`

- `assets/servicios-foto/consulta.png (1,27 MB)`
- `assets/servicios-foto/vacunacion.jpg`
- `assets/servicios-foto/profilaxis.jpg`
- `assets/servicios-foto/oncologia.png`
- `assets/servicios-foto/endoscopia.webp`
- `assets/servicios-foto/radiologia.jpg`
- `assets/servicios-foto/cirugia.webp`
- `assets/servicios-foto/desparasitacion.jpg`
- `assets/servicios-foto/laboratorio.webp`
- `assets/foto-main.webp (por conectar)`
- `assets/logoblanco.webp (por conectar)`
- `assets/logocolor.webp (por conectar)`
- `assets/logocorto.webp (por conectar)`
- `assets/logocortoblanco.webp (por conectar)`
- `public/icons.svg`
- `public/favicon.svg (plantilla de Vite)`